

What is audit trail. What are the challenges in maintaining integrity of audit trail.

An audit trail is a record of the activities or transactions within a system, showing the history of data creation, modification, and deletion. It includes details such as who made changes, when, and what specific changes were made. Audit trails are essential in systems like financial applications, healthcare, security, and compliance to ensure transparency, accountability, and integrity.

The challenges are:

Tampering and Unauthorized Access: Audit trails can be vulnerable to modification or deletion by unauthorized users, leading to loss of critical information.

Data Storage and Management: The large volume of audit logs can be difficult to store and manage, potentially affecting system performance.

Real-time Monitoring: Monitoring audit trails for suspicious or unauthorized activities can be resource-intensive and complex.

Compliance with Regulations: Adhering to industry-specific audit trail retention and security standards can be challenging, with penalties for non-compliance.

Ensuring Non-repudiation: Preventing users from denying their actions requires secure mechanisms, which can be difficult to implement effectively.

Performance Overhead: The extra processing required to log every action in real-time can slow down system performance.

Retention Period: Determining the appropriate length of time to retain audit trails can be difficult, balancing legal, operational, and storage considerations.

What is honeypots in cyber security. How it enhances the security & write its benefits.

A honeypot in cybersecurity is a decoy system or network designed to attract attackers by simulating vulnerabilities. Its purpose is to observe and analyze attackers' techniques, behavior, and tools without exposing critical systems or data. Honeypots act as bait, diverting malicious activity from real assets and providing valuable insights into potential threats.

It enhances the security by:

Threat Detection: By luring attackers, honeypots can detect unknown threats or zero-day exploits before they target actual systems.

Intrusion Analysis: Honeypots collect detailed information on the methods and tools used by attackers, helping security teams understand attack vectors.

Distraction: They act as decoys, diverting attackers from legitimate systems, reducing the risk to critical infrastructure.

Early Warning: Honeypots provide an early indication of potential attacks, allowing security teams to respond faster and enhance defenses.

Its benefits are:

Improved Threat Intelligence: Honeypots provide real-world data on attacker behavior, helping to improve security measures and defenses.

Detection of Insider Threats: Honeypots can identify malicious activity from insiders or compromised accounts by monitoring unauthorized access attempts.

Reduced False Positives: Unlike traditional detection systems, honeypots only interact with unauthorized users, reducing false positives and improving alert accuracy.

Cost-effective: Honeypots can be cheaper to deploy than comprehensive monitoring systems, as they only need to monitor specific decoy systems.

Research and Learning: Security teams can use honeypots to study the latest cyberattack techniques and test new defensive strategies in a controlled environment.

Define Discretionary Access Control. Writes its advantages and limitations.

Discretionary Access Control (DAC) is a type of access control system where the owner of a resource (such as a file or directory) has the authority to determine who can access it and what actions (read, write, execute) they can perform. The owner can assign permissions to other users at their discretion.

Its advantages are:

Flexibility: DAC offers high flexibility as the resource owner has control over access permissions and can modify them as needed without administrator intervention.

User-Centric Control: Resource owners can share their resources with specific users or groups without requiring complex permissions or admin approval.

Ease of Implementation: It is relatively simple to implement since the system only requires users to set permissions for their own resources.

Convenient for Collaboration: Since users can directly manage permissions, DAC is convenient for environments where collaboration and frequent sharing of resources are common.

Its limitations are:

Security Risks: DAC can be less secure because users might inadvertently or intentionally grant access to unauthorized users, increasing the risk of data breaches.

Lack of Centralized Control: It does not offer centralized control, making it hard for administrators to enforce organizational security policies uniformly across the system.

Propagation of Permissions: Permissions can be easily propagated if the resource owner is not careful, leading to unintentional access by users who should not have it.

Vulnerable to Malware: If a user's account is compromised, the attacker can inherit all the permissions granted to that user, potentially leading to further damage.

What is Two-factor Authentication. Write differences between single factor authentication and Two-factor Authentication.

Two-factor authentication (2FA) is a security mechanism that requires users to provide two forms of identification to verify their identity. It enhances security by combining two different factors from the following categories:

Something you know: Password or PIN

Something you have: Mobile phone, hardware token, or smart card

Something you are: Biometric data like fingerprints or facial recognition

Aspect	Single-Factor Authentication (SFA)	Two-Factor Authentication (2FA)
Authentication Method	Requires only one form of identification (usually a password)	Requires two forms of identification (e.g., password + a mobile code).
Security Level	Less secure due to reliance on one method, making it more vulnerable to attacks like password theft.	More secure by adding an additional layer of protection, reducing the risk of unauthorized access.
Ease of Use	Easier and quicker to use as only one step is involved.	Slightly less convenient as it requires an extra step to verify identity.
Vulnerability	Susceptible to attacks like phishing, brute force, or keylogging.	Offers protection against many attacks since both factors need to be compromised.
Common Usage	Used in simple login systems where high-level security is not required.	Commonly used in banking, email, and secure online services to ensure a higher level of security.

What is Computer Security? List and briefly define fundamental security design principles.

Computer security, also known as cybersecurity, refers to the protection of computer systems and networks from theft, damage, unauthorized access, or disruption of services. It ensures confidentiality, integrity, and availability of data and systems, safeguarding them against various threats like malware, hacking, and phishing.

Fundamental principles:

Least Privilege: Each user, program, or system component should operate with the minimum privileges necessary to perform its function, reducing the risk of misuse or compromise.

Separation of Duties: Responsibilities should be divided among multiple users or processes to ensure that no single entity has control over critical tasks, preventing fraud and abuse.

Fail-Safe Defaults: Systems should default to a secure state in case of failure or error, ensuring that access is denied by default unless explicitly granted.

Defense in Depth: Multiple layers of security controls should be implemented to protect against different types of threats, ensuring redundancy in case one layer is compromised.

Open Design: Security should not depend on the secrecy of the design or implementation. Systems should be secure even if the design is known, allowing for peer review and assessment.

Complete Mediation: Every access request to a resource should be checked against authorization rules, ensuring that permissions are always enforced, and nothing is bypassed.

Economy of Mechanism: Security mechanisms should be simple and straightforward to minimize errors, making them easier to understand, implement, and manage securely.

Least Common Mechanism: Shared resources should be minimized to reduce the likelihood of one process affecting the security of another through resource-sharing vulnerabilities.

Psychological Acceptability: Security mechanisms should not hinder usability. If security is too difficult or inconvenient for users, they may circumvent or avoid it, weakening the overall security.

Accountability: Actions should be traceable to the individual responsible, ensuring that all activities can be logged, monitored, and reviewed for potential security violations.

Layered Security (Security in Layers): Security mechanisms should be implemented at multiple layers (network, host, application) to create a comprehensive defense, so if one layer fails, the others can still provide protection.

Work Factor: Security measures should be strong enough that the cost or effort required to bypass them is greater than the potential gain for the attacker.

What is digital signature. Write the steps for public key cryptography with digital signature.

A digital signature is a cryptographic technique used to validate the authenticity and integrity of a message, document, or software. It ensures that the message comes from the claimed sender and has not been altered. Digital signatures are widely used in emails, software distribution, and other cases where the authenticity of digital information is important.

Steps for Public Key Cryptography with Digital Signatures:

Key Pair Generation: The sender generates a pair of cryptographic keys: a private key and a public key. The private key is kept secret, while the public key is shared with others.

Message Hashing: The sender applies a cryptographic hash function to the message, producing a fixed-size hash value (message digest). This digest represents the content of the message.

Signing the Hash: The sender uses their private key to encrypt the hash value, creating the digital signature. This signature is unique to both the message and the sender's private key.

Transmitting the Message: The sender sends the original message along with the digital signature to the recipient.

Signature Verification: The recipient uses the sender's public key to decrypt the digital signature, obtaining the original hash value created by the sender.

Recomputing the Hash: The recipient applies the same cryptographic hash function to the received message and generates a new hash value.

Comparing Hash Values: The recipient compares the decrypted hash (from the digital signature) with the recomputed hash. If both hash values match, it proves that the message is authentic and has not been tampered with.